SPEAR PHISHING DONALD TRUMP

Momento migliore non c'e' per andare a scavare e cercare di frodare la persiona piu odiata e disprezzata dopo la morte del duo musso hitler.

Come argomento principale della lezione di oggi, abbiamo sperimentato il phishing. la possibilita' di sbirciare e informarci su qualcuno potenzialmente a noi malevolo con un attacco di Phishing. 'Spear' è indirizzata ad unas persona fisica.

L'attacco phishing consiste

- ***L'esca: Ricevi un messaggio (email, SMS o social) che sembra provenire da una fonte affidabile: la tua banca, un corriere (come Amazon o Poste Italiane), o un social network.***

- ***L'urgenza: Il messaggio crea un senso di allarme. Ad esempio: "Il tuo account è stato sospeso" o "C'è un pacco in attesa di consegna, paga 2€ di costi di spedizione".***

- ***L'azione: Ti viene chiesto di cliccare su un link che conduce a un sito web falso, identico a quello originale.***

- ***Il furto: Una volta inseriti i tuoi dati nel sito fasullo, questi vengono inviati direttamente al truffatore.***

Prima di procedere con l'invio del messaggio trap. ,si procede con un lavoro di investigazione

1.Il Target (Chi colpire)
Non tutte le esche vanno bene per tutti i pesci. La scelta del bersaglio determina tutto il resto:

- ***Phishing generico: Si punta alla massa (es. clienti di una grande banca o utenti Amazon).***

- ***Spear Phishing: Si colpisce una persona specifica o un reparto aziendale (es. l'ufficio contabilità), usando informazioni reali trovate su LinkedIn o sul sito aziendale.***

SPEAR PHISHING DONALD TRUMP

2. Il Pretesto (L'esca)
È la narrazione utilizzata per convincere la vittima. I temi più comuni sfruttano leve psicologiche forti:

- ***Urgenza/Paura: "Accesso non autorizzato, blocca subito il conto".***
- ***Avidità/Opportunità: "Hai vinto un buono sconto da 500€".***
- ***Curiosità/Dovere: "Vedi la fattura allegata" o "Nuove direttive aziendali COVID-2026".***

3. L'Infrastruttura (Il mezzo)
Per rendere la truffa credibile, servono strumenti tecnici:

- ***Mittente contraffatto (Spoofing): L'indirizzo email sembra reale (es. servizio@amazon-supporto.it invece di amazon.it).***
- ***Landing Page: Un sito web clone, visivamente identico all'originale, dove l'utente inserirà i dati.***
- ***Payload (Il carico): Il link malevolo o un allegato infetto (spesso un PDF o un file Excel con macro) che installa malware o ruba sessioni di login.***

4. La Raccolta Dati (Il bottino)
Le info che una campagna mira a sottrarre sono solitamente:

- ***Credenziali: Username e Password (spesso per email o portali aziendali).***
- ***Dati Finanziari: Numeri di carta di credito e codici CVV.***
- ***Informazioni di Sistema: Versione del browser e del sistema operativo (utili per attacchi tecnici successivi).lica, ovvero trovando informazioni cruciali quali***

SPEAR PHISHING DONALD TRUMP

I NOSTRI TARGET

Categoria, Dettaglio / Valore

Sede Principale Trump_Tower WEB_Site trump.com/connect.

Residenza / Club,Mar-a-Lago

- ***societa' con il MAX Asset $564 M da me scelta come obbiettivo della campagna***

Organizzazione Trump_Organization Email @trumporg.com

Numero Dipendenti 5.000

Valore Commerciale (Trump Tower) $600.000.000

Carica: CEO

- ***Donald Trump Jr(Sede: Trump Tower) Email trjr@trumporg.com tryump@trumporg.com***

Carica: COO

- ***Matthew Calamari Email COOmatt@trumporg.com***

Altre Figure Chiave

- ***Eric Trump Email trumpceeo@trumporg.com***

Servizi e Hospitality

- ***"Trump Grill, Trump Bar" Email eat&drink@trumporg.com***

Settori Operativi

- ***"Edilizia, Contabilità, Management"***

Settore contabilita' Email payline@trumporg.com

SPEAR PHISHING DONALD TRUMP

Azienda edilizia Mar a lago

PRESIDENTBuilding spa

L'azienda PRESIDENTBuilding spa è l'azienda che si occupa di tutti gli interventi interni ed esterni della Tenuta storica di 128 stanze su 17 acri

……..RESIDENZA DEL PRESIDENTE E CLUB ESCLUSIVO PER I SOCI……..

EMAIL DELLA'AZIENDA

SHOP buynowps@trumporg.com

CONTABILITA' distribution@trumporg.com

AMMINISTRAZIONE admin@trumporg.com

Dopo aver fatto un'ampia ricerca di tutti i dati sensibili che mi potevano aiutare nel formulare una mail di richiesta nei confrnti della societa, prima di costruzione e poi il target deciso che sarebbe la struttura di punta delle societa di Trump "Mar a Lago"

Il progetto ci chiedeva direttamente di scrivere una mail di phishing al target, io dato la Persona devo cercare di entrarci in maniera diversa. Devo inviare una mail (phishing) prima alla societa di costruzione, per permettermi di ,una volta entrato,avere accesso alla loro email diretta di contabilita e pagamenti.

Fatto questo sarei pronto per cercare di farmi pagare un lavoro mai esistito ,con un'altra mail che richiede direttamente alla Trumporg il pagamento di esso. Questo dovrebbe essere possibile perche noi inviamo /riceviamo/ visualizziamo le mail dell'azienda dato che siamo entrati nel server grazie alla precedente mail di phishing.

La mail potrebbe non essere la nostra unica arma da poter sfruttare, perche' oggi si puo tranquillamente travisare sia la voce che il video rendendo la campagna ancora piu' realistica.

SPEAR PHISHING DONALD TRUMP

LA NOSTRA MAIL PER LE CREDENZIALI admin@trumporg.com

Oggetto: SOLLECITO: Azione richiesta sull'account di pagamento - ID Transazione #99281

Da: Supporto Sicurezza IT security-alert@microsoft-verify.net ……..FAKE MAIL……..

Testo:

Gentile utente,

Abbiamo rilevato un tentativo di accesso non autorizzato al portale contabilità dalla posizione: Lagos, Nigeria.

Per motivi di sicurezza, l'accesso alla casella paynow@azienda.com è stato temporaneamente limitato. Per ripristinare le funzionalità di invio e ricezione delle fatture e prevenire la sospensione definitiva dell'account, è necessario verificare la propria identità entro le prossime 4 ore.

Si prega di cliccare sul link sottostante e seguire le istruzioni:

[VERIFICA ACCOUNT E RIPRISTINA ACCESSO] (link malevolo: http://bit.ly/ORG-portale-login)

…….LINK MALEVOLO……..

Se non effettuerai la verifica, l'account verrà disabilitato permanentemente per proteggere i dati aziendali.

Distinti saluti,

Il Team di Sicurezza Informatica

UNA VOLTA INVIATA ASPETTIAMO CHE IL DIPENDENTE SEGUA IL PROCESSO COSI DA OTTENERE L'ACCESSO ALL'AZIENDA.

SPEAR PHISHING DONALD TRUMP

LA NOSTRA MAIL PER IL PAGAMENTO payline@trumporg.com

Oggetto: SOLLECITO: Fattura Scaduta n. 2024-V99 - Azione Immediata Richiesta

Da: Amministrazione Fornitori distribution@trUmporg.com ……..FAKE MAIL……..

(Nota: il dominio reale del fornitore sarebbe trump.com, non trUmp.com)

Testo:

Gentile Team Amministrativo,

Vi informiamo che, a seguito di un controllo contabile, risulta ancora non saldata la fattura n. 2024-V99 relativa al rinnovo dei servizi infrastrutturali del mese scorso.

A causa del mancato pagamento, il sistema procederà alla sospensione automatica delle licenze attive entro 24 ore. Per evitare l'interruzione dei servizi e l'addebito di penali per mora, vi preghiamo di prendere visione del documento allegato e confermare l'avvenuto bonifico.

Abbiamo inoltre aggiornato le nostre coordinate bancarie (IBAN) per le operazioni internazionali. Potete trovare i nuovi dettagli nel portale dedicato.

Visualizza Fattura e Coordinate di Pagamento:

[ACCEDI AL PORTALE PAGAMENTI]

http://portale-pagamenti-sicuri.net/login/azienda ……LINK MALEVOLO……..

In alternativa, scaricate l'allegato:

- *Fattura_Scaduta_2024_V99.zip …….LINK MALEVOLO…….*

Cordiali saluti,

SPEAR PHISHING DONALD TRUMP

Ufficio contabilita

PRESIDENTBuildin Spa

Non dimentichiamo che l'accesso con la prima mail non scade velocemente, si potrebbe protrarre per 90gg.

Al fine di non cadere nella trappola di qualsiasi metodo di phishing usato, la ZERO TRUST e' la migliore scelta.

FIDUCIA ZERO.

Anche io avrei risposto alle due mail ricevute perche' siamo sempre sopraffatti dai fattori citati ad inizio report.